Практическая работа: Разработка модели угроз для учебной АСУТП

Выбор отрасли функционирования АСУТП

Отрасль: Электроэнергетика

Наименование АСУТП: Автоматизированная система оперативно-диспетчерского управления объектами электроэнергетики (АСОДУ)

Шаг 1–2. Границы моделирования

Учебная АСУТП: Как описано в задании, это распределённая автоматизированная система управления географически рассредоточенными технологическими процессами (подстанциями, распределительными устройствами), находящимися на расстоянии нескольких километров. Обмен данными и передача команд управления осуществляются только по проводным каналам связи.

Объекты защиты (компоненты АСУТП):

- Серверы (SCADA-серверы, коммутационные серверы, серверы реального времени), в том числе виртуальные
- Рабочие станции (клиентская часть SCADA-системы)
- Телекоммуникационное оборудование
- Каналы связи (проводные)
- Мобильные устройства (инженерные станции)

Шаг 3–4. Возможные негативные последствия от реализации угроз

Негативные последствия	**Объекты воздействия**

Нарушение целостности управляющих команд, подаваемых на оборудование подстанций, что может привести к аварийному отключению потребителей электроэнергии	SCADA-серверы, серверы реального времени, каналы связи
Несанкционированное изменение уставок и параметров релейной защиты и автоматики (РЗА), приводящее к некорректному срабатыванию защит	Программируемые логические контроллеры (ПЛК), рабочие станции
Отказ в обслуживании диспетчерских систем, невозможность получения телеметрической информации с объектов	SCADA-серверы, коммутационные серверы, телекоммуникационное оборудование
Хищение конфиденциальной информации о режимах работы энергосистемы, топологии сети, уязвимостях объектов	Серверы, рабочие станции, каналы связи
Несанкционированное отключение контрольных датчиков и систем мониторинга, что скрывает от диспетчера реальное состояние оборудования	Датчики, ПЛК, каналы связи
Физическое повреждение или вывод из строя оборудования подстанций в результате подачи запрещённых команд	Исполнительные механизмы, ПЛК, серверы
Блокирование доступа диспетчеров к системе управления, невозможность выполнения оперативных переключений	Рабочие станции, серверы, средства защиты информации
Нарушение температурного режима в серверных помещениях, приводящее к выходу из строя вычислительного оборудования	Технические средства воздушного кондиционирования, серверы

Утечка информации по скрытым каналам через телекоммуникационное оборудование	Телекоммуникационное оборудование, каналы связи
Несвоевременное выявление инцидентов информационной безопасности, что позволяет нарушителю беспрепятственно реализовывать угрозы	Средства защиты информации, серверы, рабочие станции

Шаг 5–6. Модель нарушителя

Виды нарушителей	**Категории нарушителей**	**Возможные цели реализации угроз безопасности информации**
Внешний нарушитель (киберпреступные группировки, хактивисты, конкуренты, террористические организации)	Высокий потенциал: обладают значительными финансовыми и техническими ресурсами, специализированным вредоносным ПО, знаниями в области АСУТП и SCADA-систем	Дестабилизация работы энергосистемы, причинение экономического ущерба, хищение коммерческой информации, проведение кибертеррористических актов
Внешний нарушитель (квалифицированные хакеры)	Средний потенциал: обладают достаточными техническими знаниями и инструментами для эксплуатации уязвимостей	Несанкционированный доступ к системе управления, перехват управления технологическим процессом, вывод оборудования из строя

Внешний нарушитель (неквалифицированные злоумышленники)	Низкий потенциал: используют готовые инструменты и эксплойты, не обладают глубокими знаниями об АСУТП	Случайное или намеренное нарушение доступности системы, заражение системы вредоносным ПО
Внутренний нарушитель (действующий сотрудник с умыслом — disgruntled employee)	Высокий потенциал: имеет легальный доступ к системе, знание архитектуры АСУТП, процедур и средств защиты	Саботаж технологического процесса, хищение информации, умышленный вывод оборудования из строя, сокрытие следов противоправных действий
Внутренний нарушитель (действующий сотрудник по неосторожности)	Низкий потенциал: не имеет умысла, но нарушает правила информационной безопасности по халатности	Случайное заражение системы вредоносным ПО, непреднамеренное изменение параметров системы, утеря носителей информации
Внутренний нарушитель (бывший сотрудник, сохранивший доступ)	Средний потенциал: обладает знаниями об архитектуре системы и может использовать не отозванные учётные данные	Несанкционированный доступ к системе, внесение деструктивных изменений, хищение информации

Шаг 7. Сценарии реализации угроз (кратко)

Для каждого актуального нарушителя существуют следующие сценарии:

1. **Внешний нарушитель (высокий потенциал):** Целевая атака на SCADA-сервер через эксплуатацию уязвимостей в сетевом ПО → перехват управления ПЛК →

подача запрещённых команд на исполнительные механизмы → аварийное отключение подстанции.

2. **Внешний нарушитель (средний потенциал):** Сканирование сети → обнаружение открытых портов телекоммуникационного оборудования → эксплуатация уязвимостей → перехват трафика в каналах связи → искажение телеметрических данных.
3. **Внутренний нарушитель (действующий сотрудник с умыслом):** Использование легальных учётных данных → несанкционированное изменение уставок РЗА → некорректное срабатывание защит → каскадное отключение потребителей.
4. **Внутренний нарушитель (по неосторожности):** Подключение заражённого мобильного устройства (инженерной станции) к сети АСУТП → распространение вредоносного ПО на SCADA-серверы → отказ в обслуживании.

Шаг 8. Перечень актуальных угроз

Идентификатор УБИ	**Наименование УБИ**	**Описание**	**Источник угрозы (характеристика и потенциал нарушителя)**	**Объект воздействия**
23	Угроза изменения компонентов информационной (автоматизированной) системы	Несанкционированное изменение состава программных или аппаратных средств АСУТП	Внутренний нарушитель с низким потенциалом	Информационная система, сервер, рабочая станция, системное программное обеспечение, прикладное программное обеспечение, аппаратное обеспечение

27	Угроза искажения вводимой и выводимой на периферийные устройства информации	Подмена или искажение данных, поступающих от датчиков или выводимых на дисплей оператора	Внешний нарушитель с высоким потенциалом; Внутренний нарушитель с низким потенциалом	Системное программное обеспечение, прикладное программное обеспечение, сетевое программное обеспечение, аппаратное обеспечение
34	Угроза использования слабостей протоколов сетевого/локального обмена данными	Несанкционированный доступ к передаваемой информации за счёт деструктивного воздействия на протоколы обмена	Внешний нарушитель с низким потенциалом; Внутренний нарушитель с низким потенциалом	Системное программное обеспечение, сетевое программное обеспечение, сетевой трафик
63	Угроза некорректного использования функционала программного и аппаратного обеспечения	Использование декларированных возможностей программных и аппаратных средств нестандартным способом	Внешний нарушитель со средним потенциалом; Внутренний нарушитель со средним потенциалом	Системное программное обеспечение, прикладное программное обеспечение, сетевое программное обеспечение, микропрограммное обеспечение, аппаратное обеспечение

67	Угроза неправомерного ознакомления с защищаемой информацией	Неправомерное ознакомление пользователя с информацией, которая для него не предназначена	Внутренний нарушитель с низким потенциалом	Аппаратное обеспечение, носители информации, объекты файловой системы
69	Угроза неправомерных действий в каналах связи	Внесение изменений в работу сетевых протоколов путём добавления или удаления данных из информационного потока	Внешний нарушитель с низким потенциалом	Сетевой трафик
88	Угроза несанкционированного копирования защищаемой информации	Неправомерное получение копии защищаемой информации	Внешний нарушитель с низким потенциалом; Внутренний нарушитель с низким потенциалом	Объекты файловой системы, машинный носитель информации
91	Угроза несанкционированного удаления защищаемой информации	Удаление информации путём деструктивного программного или физического воздействия	Внешний нарушитель с низким потенциалом; Внутренний нарушитель с низким потенциалом	Метаданные, объекты файловой системы, реестр
92	Угроза несанкционированного удалённого внеполосного доступа к аппаратным средствам	Получение привилегий управления системой путём использования удалённого внеполосного доступа	Внешний нарушитель с высоким потенциалом	Информационная система, аппаратное обеспечение

94	Угроза несанкционированного управления синхронизацией и состоянием	Изменение последовательности действий, выполняемых приложениями, или модификация настроек промышленных устройств	Внешний нарушитель со средним потенциалом; Внутренний нарушитель со средним потенциалом	Системное программное обеспечение, прикладное программное обеспечение, сетевое программное обеспечение, микропрограммное обеспечение
107	Угроза отключения контрольных датчиков	Обеспечение информационной изоляции системы безопасности путём прерывания канала связи с контрольными датчиками	Внешний нарушитель с высоким потенциалом; Внутренний нарушитель с низким потенциалом	Системное программное обеспечение
111	Угроза передачи данных по скрытым каналам	Неправомерный вывод защищаемой информации из системы путём её нестандартного размещения в легитимных данных	Внешний нарушитель со средним потенциалом; Внутренний нарушитель со средним потенциалом	Сетевой узел, сетевое программное обеспечение, сетевой трафик

115	Угроза перехвата вводимой и выводимой на периферийные устройства информации	Несанкционированный доступ к информации, вводимой и выводимой на периферийные устройства	Внешний нарушитель с низким потенциалом; Внутренний нарушитель с низким потенциалом	Системное программное обеспечение, прикладное программное обеспечение, аппаратное обеспечение
116	Угроза перехвата данных, передаваемых по вычислительной сети	Несанкционированный доступ к сетевому трафику в пассивном или активном режиме	Внешний нарушитель с низким потенциалом	Сетевой узел, сетевой трафик
122	Угроза повышения привилегий	Деструктивное воздействие на процесс или систему путём эксплуатации неправомерно полученных дополнительных прав	Внешний нарушитель со средним потенциалом; Внутренний нарушитель со средним потенциалом	Системное программное обеспечение, сетевое программное обеспечение, информационная система
130	Угроза подмены содержимого сетевых ресурсов	Скрытная подмена содержимого хранящихся или передаваемых по сети данных	Внешний нарушитель с низким потенциалом	Прикладное программное обеспечение, сетевое программное обеспечение, сетевой трафик

139	Угроза преодоления физической защиты	Осуществление деструктивных действий при получении физического доступа к аппаратным средствам	Внешний нарушитель со средним потенциалом	Сервер, рабочая станция, носитель информации, аппаратное обеспечение
140	Угроза приведения системы в состояние «отказ в обслуживании»	Отказ системы в доступе легальным пользователям при лавинообразном увеличении числа соединений	Внешний нарушитель с низким потенциалом; Внутренний нарушитель с низким потенциалом	Информационная система, сетевой узел, системное программное обеспечение, сетевое программное обеспечение, сетевой трафик, телекоммуникационное устройство
143	Угроза программного выведения из строя средств хранения, обработки и (или) ввода/вывода/передачи информации	Прерывание технологии обработки информации путём деструктивного программного воздействия	Внешний нарушитель со средним потенциалом; Внутренний нарушитель со средним потенциалом	Носитель информации, микропрограммное обеспечение, аппаратное обеспечение, телекоммуникационное устройство
157	Угроза физического выведения из строя средств хранения, обработки и (или) ввода/вывода/передачи информации	Умышленное выведение из строя средств хранения, обработки и ввода/вывода информации	Внешний нарушитель с низким потенциалом	Сервер, рабочая станция, носитель информации, аппаратное обеспечение

160	Угроза хищения средств хранения, обработки и (или) ввода/вывода/передачи информации	Кража компьютера, USB-накопителей, оптических дисков или других средств	Внешний нарушитель с низким потенциалом	Сервер, рабочая станция, носитель информации, аппаратное обеспечение
177	Угроза неподтверждённого ввода данных оператором в систему, связанную с безопасностью	Возникновение ошибок в работе системы вследствие отсутствия процедуры обнаружения и исправления ошибок	Внутренний нарушитель с низким потенциалом	Системное программное обеспечение, сетевое программное обеспечение, прикладное программное обеспечение, аппаратное обеспечение
179	Угроза несанкционированной модификации защищаемой информации	Нарушение целостности защищаемой информации путём деструктивного воздействия	Внешний нарушитель с низким потенциалом; Внутренний нарушитель с низким потенциалом	Объекты файловой системы
180	Угроза отказа подсистемы обеспечения температурного режима	Повреждение компонентов системы вследствие выхода температурного режима из заданных требований	Внутренний нарушитель с низким потенциалом; Внешний нарушитель со средним потенциалом	Технические средства воздушного кондиционирования, программируемые логические контроллеры, распределённые системы контроля

183	Угроза перехвата управления автоматизированной системой управления технологическими процессами	Несанкционированный доступ к информационной инфраструктуре за счёт получения права управления АСУТП	Внешний нарушитель с высоким потенциалом; Внутренний нарушитель со средним потенциалом	Программное обеспечение автоматизированной системы управления технологическими процессами
185	Угроза несанкционированного изменения параметров настройки средств защиты информации	Несанкционированное изменение параметров настройки средства защиты информации	Внешний нарушитель с низким потенциалом; Внутренний нарушитель с низким потенциалом	Средство защиты информации
187	Угроза несанкционированного воздействия на средство защиты информации	Несанкционированный доступ к программной среде управления средством защиты информации	Внешний нарушитель со средним потенциалом; Внутренний нарушитель со средним потенциалом	Средство защиты информации
204	Угроза несанкционированного изменения вредоносной программой значений параметров программируемых логических контроллеров	Несанкционированное изменение значений параметров контроля и управления исполнительными устройствами в ПЛК	Внешний нарушитель со средним потенциалом	Аппаратное устройство

205	Угроза нарушения работы компьютера и блокирования доступа к его данным из-за некорректной работы установленных на нем средств защиты	Нарушение работы компьютера и отказ в доступе к его данным за счёт ошибочного блокирования файлов	Внешний нарушитель с низким потенциалом	Аппаратное устройство, программное обеспечение
210	Угроза нарушения работы информационной системы, вызванного обновлением используемого в ней программного обеспечения	Нарушение функционирования программных и программно-аппаратных элементов из-за некорректной работы обновлений	Внутренний нарушитель с высоким потенциалом	Аппаратное устройство, микропрограммное, системное и прикладное программное обеспечение
212	Угроза перехвата управления информационной системой	Несанкционированный доступ к ресурсам информационной системы в результате подмены средств централизованного управления	Внутренний нарушитель со средним потенциалом	Инфраструктура информационных систем
214	Угроза несвоевременного выявления и реагирования компонентами информационной системы на события безопасности информации	Пропуск и/или значительная временная задержка определения событий безопасности информации	Внутренний нарушитель со средним потенциалом	Программное обеспечение, каналы связи (передачи) данных

Шаг 9. Проект модели угроз безопасности информации

№ п/п	Раздел	Содержание раздела
1	Общие положения	
1.1	Наименование объекта защиты	Автоматизированная система оперативно-диспетчерского управления объектами электроэнергетики (АСОДУ). Автоматизированный данной АСУТП критический процесс — оперативно-диспетчерское управление режимами работы объектов электроэнергетики (подстанций, распределительных устройств), включая сбор телеметрической информации, передачу команд управления и контроль состояния оборудования.

1.2	Информация об использованных нормативно-методических документах	1. Методический документ ФСТЭК России «Методика моделирования угроз безопасности информации», утверждён ФСТЭК России 5 февраля 2021 года. 2. ГОСТ Р 56546-2015 «Защита информации. Уязвимости информационных систем. Классификация уязвимостей информационных систем». 3. Банк данных угроз безопасности информации ФСТЭК России (bdu.fstec.ru). 4. Приказ ФСТЭК России от 25.12.2017 № 239 «Об утверждении Требований по обеспечению безопасности значимых объектов критической информационной инфраструктуры Российской Федерации».
2	Характеристика объекта защиты	Учебная АСУТП представляет собой распределённую автоматизированную систему управления, используемую для управления географически рассредоточенными технологическими процессами (площадками), которые находятся на расстоянии нескольких километров. Подобные системы применяются для автоматизации процессов управления железнодорожным движением, добычи, хранения, переработки нефти и газа, оперативно-диспетчерского управления в электроэнергетике. В рамках данной модели рассматривается АСУТП в отрасли электроэнергетики. Обмен данными и передача команд управления осуществляются только по проводным каналам связи. Компоненты АСУТП (объекты защиты): серверы (в том числе виртуальные) — SCADA-серверы, коммутационные серверы, серверы реального времени; рабочие станции — клиентская часть SCADA-системы; телекоммуникационное оборудование;

		каналы связи (проводные); мобильные устройства (инженерные станции).
3	Возможные негативные последствия от реализации угроз безопасности информации	(см. таблицу в шаге 4 выше)
4	Источники угроз безопасности информации и результаты оценки возможностей нарушителя (модель нарушителя)	(см. таблицу в шаге 6 выше)
5	Сценарии реализации угроз безопасности информации	(см. описание в шаге 7 выше)
6	Перечень актуальных угроз	(см. таблицу в шаге 8 выше)